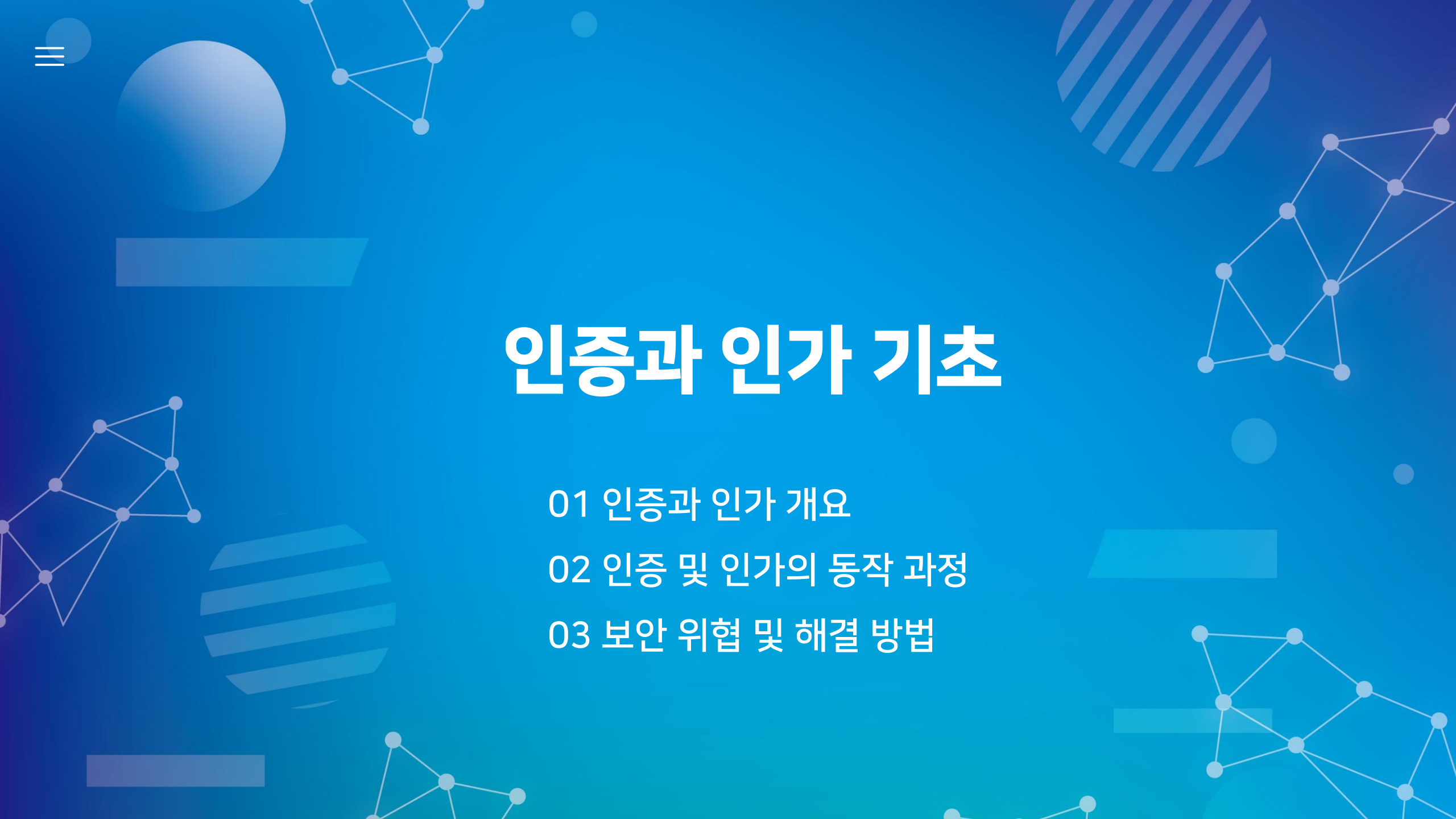


The background is a vibrant blue gradient. It is decorated with various abstract elements: a large solid blue sphere in the top left, a smaller sphere with diagonal stripes in the top right, and another striped sphere in the bottom left. Several network diagrams, consisting of interconnected nodes and lines, are scattered across the slide. There are also solid blue rectangles and trapezoids of different sizes and shades of blue.

인증과 인가 기초

01 인증과 인가 개요

02 인증 및 인가의 동작 과정

03 보안 위협 및 해결 방법



학습 목표

- ✓ 인증과 인가의 개념을 이해하고 차이점을 설명할 수 있다.
- ✓ 현대 애플리케이션 보안과제를 해결하기 위한 방안을 이해한다.
- ✓ 사고 사례를 통한 시큐어코딩을 이해한다.



학습 내용

1. 인증과 인가 개요
2. 인증 및 인가의 동작 과정
3. 보안위협 및 해결 방법



인증과 인가 기초

01 인증과 인가 개요

02 인증 및 인가의 동작 과정

03 보안 위협 및 해결방법

인증과 인가의 차이

인증(Authentication)



인증은 시스템 접근 시, 등록된 사용자인지 여부를 확인하는 것.
ex) 로그인

인가(Authorization)



인증 후 사용자에게 리소스에 접근 가능한 권한을 부여하는 것과 제한하는 것
ex) 사용자 등급(일반사용자/관리자/개인정보취급자)

그림출처: openmaru.com

인증 방식 이해

인증은 내가 “나”임을 증명하는 것으로, 인증방법에 따라 지식기반, 소유기반, 생체기반의 방식으로 구분할 수 있다.
가장 널리 사용되는 인증방식이 아이디(ID)와 패스워드(password)를 사용하는 방식이다.

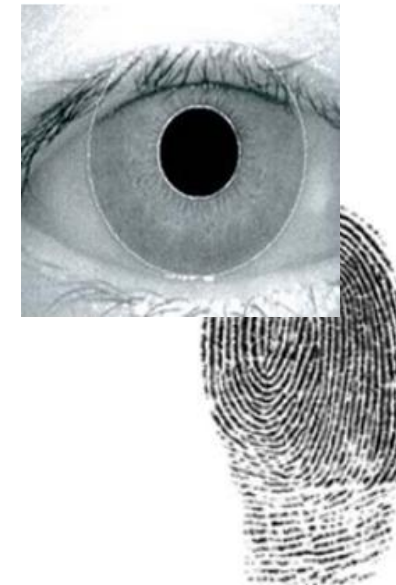
▶ 지식기반 인증(ID/PWD)



▶ 소유기반 인증



▶ 생체기반 인증



그림출처: openmaru.com

인증 방식 이해 - 지식기반 인증

정의

사용자가 알고 있는 정보를 기반으로 본인 여부를 확인하는 인증 방식(예: 비밀번호, PIN, 보안 질문)

장점

구현 및 사용이 비교적 간편하고 사용자에게 익숙 (비밀번호)

단점

사회공학적인 공격, 정보 유출 시 위험 증가, 예측 가능한 질문의 경우 보안 취약

보완 방안

다단계 인증(MFA)과 결합하여 보안 강화, 주기적인 질문 및 답변 업데이트 권장

The screenshot shows a web browser window with the URL https://auth.skt-id.co.kr/auth/authorize.do?client_id=2590d318-0816-.... The page is titled "Tworld" and "T아이디 로그인". On the left, there is a sidebar with the following links: "아이디", "T아이디(이메일)", "비밀번호", and "비밀번호". The main content area is titled "아이핀 메인 화면" and contains a login form with fields for "아이핀ID" and "비밀번호", and a "확인" button. Below the form, there are four icons representing different services: "신규발급", "ID/비밀번호찾기", "아이핀관리", and "고객센터". At the bottom, there is a navigation bar with links for "이용약관", "개인정보취급방침", "홈페이지", and "닫기".

인증 방식 이해 - 소유기반 인증

정의

사용자가 물리적으로 소유하고 있는 장치나 토큰을 기반으로 본인 확인을 수행하는 인증 방식

적용 사례

OTP (One-Time Password) 토큰. 스마트 카드 모바일 디바이스 인증

장점

실제 소유한 장치가 필요하므로, 정보 유출이나 사회공학 공격에 대한 방어력이 향상됨
지식기반 인증과 결합한 2차 인증 수단으로 활용되어 보안 강화

단점

소유하는 장치의 분실 또는 도난 시 인증이 무력화될 수 있음
추가 장치 소지 필요, 장치 재발급, 분실 신고 및 관리 체계 구축 필요,



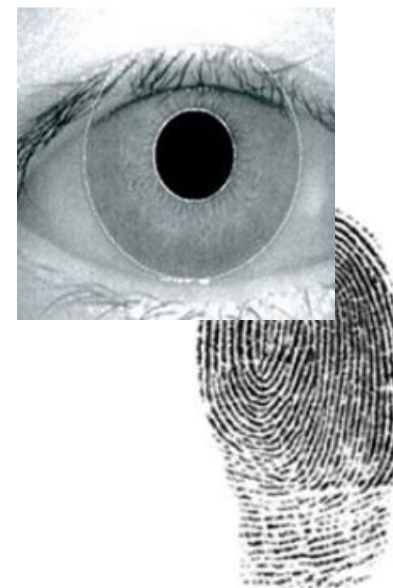
인증 방식 이해 - 생체기반 인증

정의

사용자의 신체적 또는 행동적 특성을 기반으로 본인 여부를 확인하는 인증 방식

적용 사례

- 지문 인식: 스마트폰, 노트북 등에서 흔히 사용
- 안면/홍채 인식: 보안 시스템 및 모바일 기기 잠금 해제
- 음성 인식: 콜센터나 음성 비서 인증



장점

복제나 도용이 어려워 보안성이 높음, 기억할 필요 없이 간단한 생체 정보만으로 인증하므로 편리

단점

생체 정보 유출 시 치명적 피해 우려, 조명, 소음, 센서 오류 등으로 인한 인식 실패가 잦음, 고성능 센서 및 기술 도입 비용 부담

보안강화를 위한 최신 인증 기술

비밀번호 없는 인증 (Passwordless Authentication)

(예) FIDO2, WebAuthn

공개키 기반으로 사용자 장치의 생체 인증, PIN 등을 활용하여 비밀번호 없이 인증 수행

리스크 기반 / 적응형 인증 (Risk-based/Adaptive Authentication)

로그인 시 사용자의 위치, 디바이스, 네트워크 환경, 접속 시간 등 다양한 컨텍스트 정보를 활용하여 리스크를 평가

분산 인증 (Decentralized Authentication)

(예) 분산 신원(DID, Decentralized Identity) 기반의 인증 솔루션

블록체인 등 분산원장 기술을 활용하여 중앙 집중식 사용자 데이터베이스 없이 인증 진행



인증과 인가 기초

01 인증과 인가 개요

02 인증 및 인가의 동작 과정

03 보안 위협 및 해결방법

일반적인 웹 애플리케이션의 인증/인가 프로세스

인증 방식

- 세션기반 방식
- 토큰기반 방식
- 외부 인증 방식

인가 방식

- 역할기반 접근제어(RBAC) / 속성기반 접근제어(ABAC)
- 요청에 포함된 토큰/세션 정보 기반으로 접근 권한을 갖고 있는지 확인
- 최소 권한 부여 원칙

일반적인 인증 / 인가 프로세스

- 1단계: 사용자 로그인 → 서버에서 자격 증명 확인
- 2단계: 성공 시 세션/토큰 발급 → 이후 요청 시 포함
- 3단계: API 게이트웨이나 미들웨어에서 토큰/세션 검증 → 권한에 따른 접근 제어

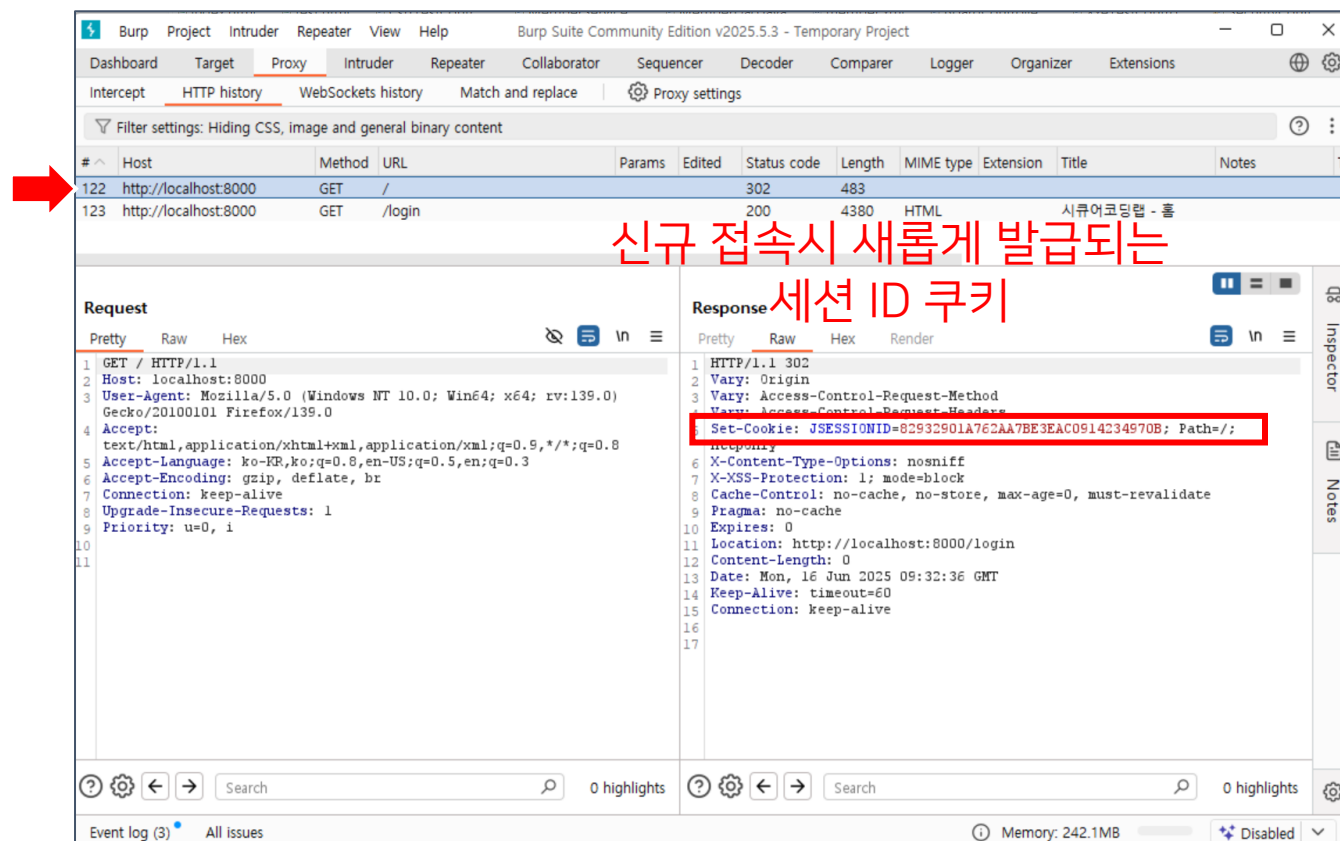
세션 기반 인증

사용자의 인증 정보가 서버의 세션 저장소에 저장되는 방식



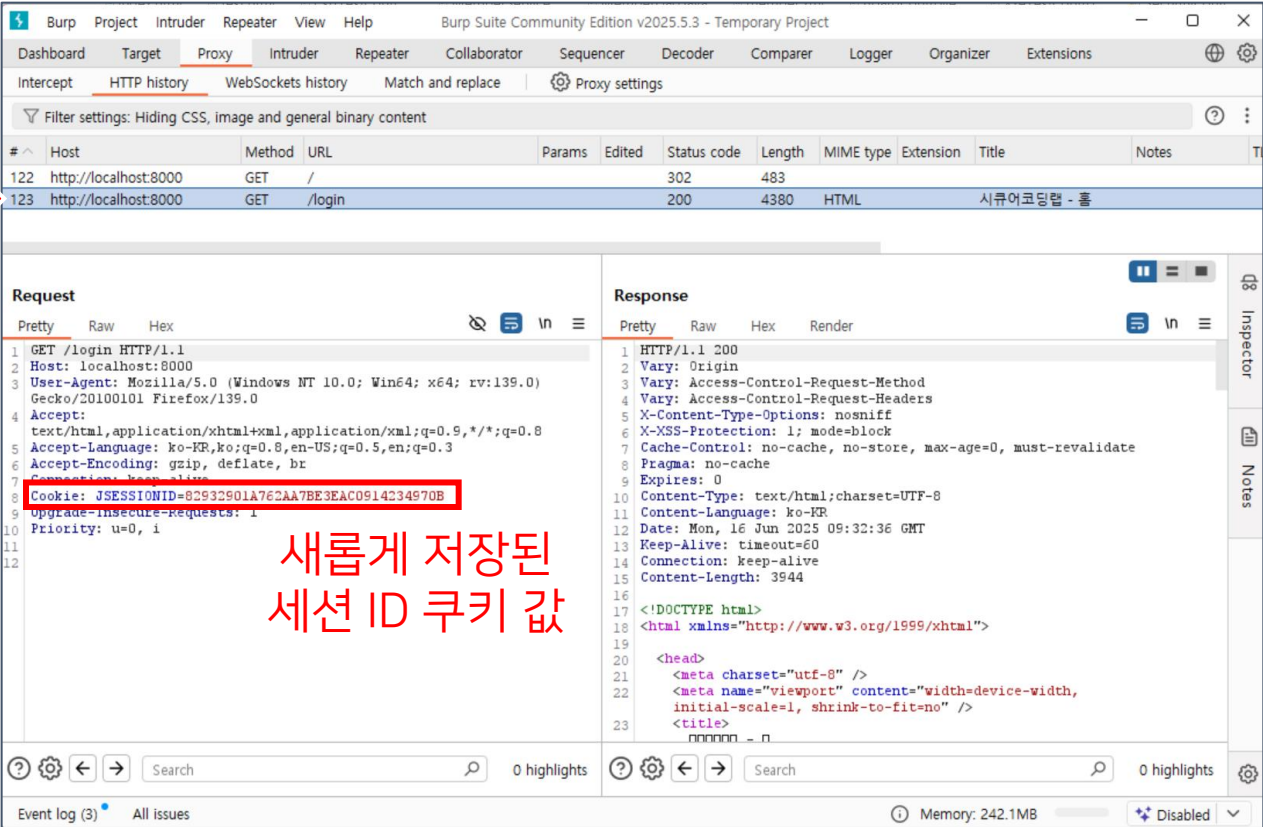
LAB 세션 처리 확인

1. BurpSuite Proxy가 Intercept Off로 동작 중인 상태에서 LAB 웹 서비스 접속 시도
2. BurpSuite Proxy 메뉴에서 HTTP History 메뉴로 들어가 최초 접속 항목을 선택
3. 하단에 HTTP Response 내용 확인



LAB 세션 처리 확인

4. HTTP History 목록에서 자동으로 이동한 로그인 페이지 요청 항목 선택
5. 하단에 HTTP Request 내용 확인
6. 새롭게 발급받은 세션 ID값이 쿠키값으로 함께 전송되는 것이 확인됨



The screenshot shows the Burp Suite interface with the HTTP History tab selected. A red arrow points to the selected request in the history table. The request details are shown in the bottom panel, and the response details are shown in the top panel.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes
122	http://localhost:8000	GET	/			302	483				
123	http://localhost:8000	GET	/login			200	4380	HTML		시큐어코딩랩 - 홈	

Request Details:

```
1 GET /login HTTP/1.1
2 Host: localhost:8000
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0)
  Gecko/20100101 Firefox/139.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: ko-KR,ko;q=0.8,en-US;q=0.5,en;q=0.3
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Cookie: JSESSIONID=82932901A762AA7BE3EAC0914234970B
9 Upgrade-Insecure-Requests: 1
10 Priority: u=0, i
```

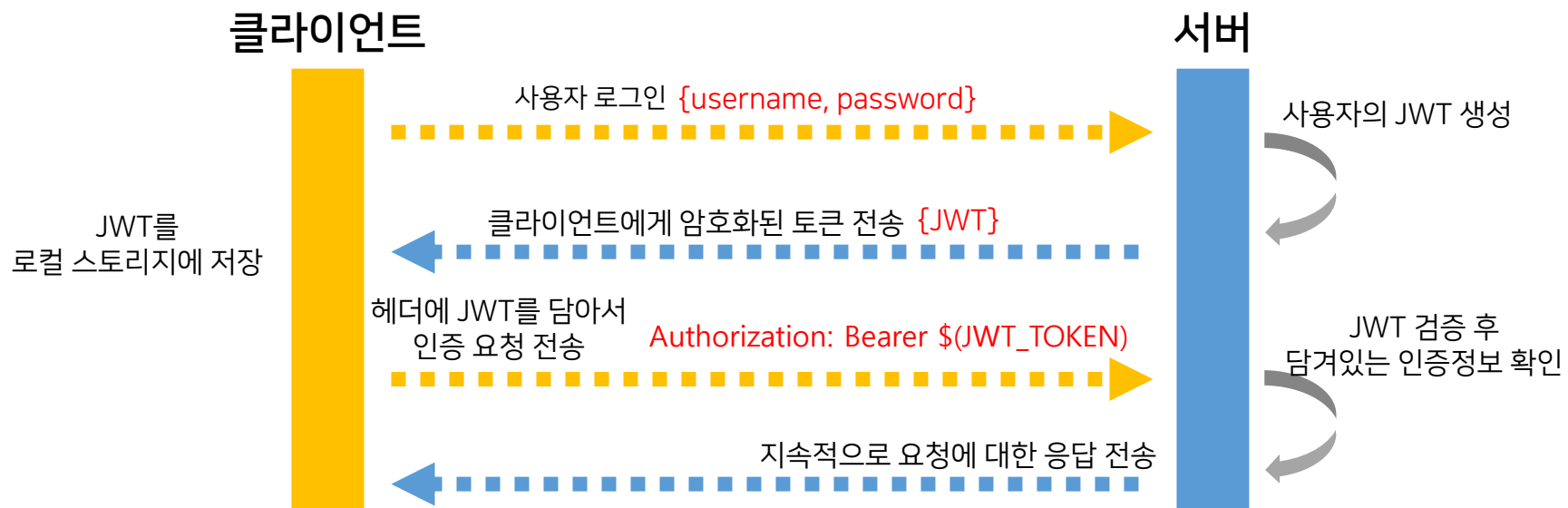
Response Details:

```
1 HTTP/1.1 200
2 Vary: Origin
3 Vary: Access-Control-Request-Method
4 Vary: Access-Control-Request-Headers
5 X-Content-Type-Options: nosniff
6 X-XSS-Protection: 1; mode=block
7 Cache-Control: no-cache, no-store, max-age=0, must-revalidate
8 Pragma: no-cache
9 Expires: 0
10 Content-Type: text/html; charset=UTF-8
11 Content-Language: ko-KR
12 Date: Mon, 16 Jun 2025 09:32:36 GMT
13 Keep-Alive: timeout=60
14 Connection: keep-alive
15 Content-Length: 3944
16
17 <!DOCTYPE html>
18 <html xmlns="http://www.w3.org/1999/xhtml">
19
20 <head>
21   <meta charset="utf-8" />
22   <meta name="viewport" content="width=device-width,
  initial-scale=1, shrink-to-fit=no" />
23   <title>
```

새롭게 저장된 세션 ID 쿠키 값

토큰 기반 인증

사용자의 인증 정보를 클라이언트가 들고 있는 방식



JWT 로그인 세션 처리 확인

1. 사용자 로그인 HTTP Request

```
POST /api/auth/login HTTP/1.1
Host: example.com
Content-Type: application/json
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/121.0.0.0 Safari/537.36
Accept: application/json
Connection: keep-alive
Content-Length: 52

{
  "username": "user123",
  "password": "securePass!"
}
```

2. 사용자 로그인 HTTP Response

- 세션 토큰이 JWT 형태로 발급됨
- 만료기간 설정됨

```
HTTP/1.1 200 OK
Content-Type: application/json
Server: nginx/1.21.3
Date: Tue, 26 Feb 2025 14:00:00 GMT
Connection: keep-alive
Content-Length: 180

{
  "access_token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",
  "token_type": "Bearer",
  "expires_in": 3600
}
```

JWT 로그인 세션 처리 확인

3. 사용자 프로필 조회 HTTP Request

Authorization 에 JWT 세션 토큰을 넣어 전송

```
GET /api/user/profile HTTP/1.1
Host: example.com
Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...
Accept: application/json
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/121.0.0.0 Safari/537.36
Connection: keep-alive
```

3. 사용자 프로필 조회 HTTP Response

```
HTTP/1.1 200 OK
Content-Type: application/json
Server: nginx/1.21.3
Date: Tue, 26 Feb 2025 14:01:00 GMT
Connection: keep-alive
Content-Length: 120

{
  "user_id": 12345,
  "username": "user123",
  "email": "user123@example.com",
  "role": "admin"
}
```



인증과 인가 기초

01 인증과 인가 개요

02 인증 및 인가의 동작 과정

03 보안 위협 및 해결방법

주요 인증 보안 위협

위협	설명	예제
비밀번호 기반 공격 (Credential Stuffing, Dictionary Attack)	공격자가 유출된 사용자 계정을 활용하여 로그인 시도	- 자동화된 스크립트로 유출된 계정/비밀번호 조합을 입력 - 쉬운 비밀번호(123456, password 등)를 대입
피싱(Phishing) & 소셜 엔지니어링	사용자에게 속여 로그인 정보를 탈취	- 가짜 로그인 페이지를 만들어 사용자 입력을 유도
중간자 공격 (MITM, Man-In-The-Middle Attack)	네트워크 트래픽을 가로채 인증 정보를 탈취	- 공용 Wi-Fi에서 패킷을 가로채 로그인 정보 수집
세션 탈취 (Session Hijacking)	공격자가 유효한 세션 ID를 도용하여 로그인 상태를 유지	- 쿠키 탈취(document.cookie), 세션 ID 도용
무차별 대입 공격 (Brute Force Attack)	여러 비밀번호를 반복 시도하여 로그인 시도	- 봇을 사용하여 다양한 비밀번호 조합을 입력
취약한 OTP / MFA (Multi-Factor Authentication) 우회	2FA(이중 인증) 우회 공격	- 2FA 코드 스니핑, SIM 스와핑(SIM Swapping)

주요 인증 보안 위협 대응 방안

대응방법	설명
강력한 비밀번호 정책	- 최소 8~12자 이상, 대문자/소문자/숫자/특수문자 조합 사용 - 비밀번호 재사용 방지 (이전 비밀번호 사용 불가)
계정 잠금 (Account Lockout)	- 일정 횟수 이상 로그인 실패 시 계정 잠금
다중 매체 인증 (MFA, Multi-Factor Authentication)	- OTP, 인증 앱(Google Authenticator), FIDO2 등 추가 인증 적용
HTTPS 사용 및 HSTS (HTTP strict-transport-security) 적용	- 네트워크 암호화(SSL/TLS) 적용
세션 보안 강화	- Secure, HttpOnly, SameSite 쿠키 적용 - 세션 타임아웃 설정
로그인 알림 및 로그 모니터링	- 로그인 시 이메일/SMS 알림 - 비정상적인 로그인 감지
CAPTCHA 적용	- 봇(Bot) 기반 로그인 시도를 방지

주요 인가 보안 위협

위협	설명	예제
권한 상승 공격 (Privilege Escalation)	낮은 권한의 사용자가 관리자 권한을 얻음	- 일반 사용자가 관리자 계정으로 변경
수평적 권한 상승 (Horizontal Privilege Escalation)	동일 권한 내에서 다른 사용자의 데이터에 접근	- user_id=123을 user_id=124로 변경하여 다른 사용자 정보 접근
수직적 권한 상승 (Vertical Privilege Escalation)	일반 사용자가 관리 권한을 얻음	- 웹 요청을 수정하여 admin=true 설정
취약한 객체 직접 참조 (IDOR, Insecure Direct Object References)	다른 사용자의 데이터에 직접 접근	- /user/1001/profile → /user/1002/profile 변경하여 다른 사용자의 정보 조회
CSRF (Cross-Site Request Forgery)	사용자의 세션을 이용하여 공격자가 악의적인 요청 수행	- 사용자가 로그인된 상태에서 공격자가 강제 요청 실행
불충분한 API 권한 검증	API 요청에서 적절한 권한 검사가 없음	- GET /admin/users API가 일반 사용자에게도 노출됨
URL 기반 접근 통제 부족	URL만 알면 누구나 접근 가능	- /admin/dashboard에 접근할 수 있는 사용자 제한이 없음

주요 인가 보안 위협 대응 방안

위협	설명
최소 권한 원칙(Principle of Least Privilege)	- 모든 사용자는 필요한 최소한의 권한만 부여
역할 기반 접근 제어 (RBAC, Role-Based Access Control)	- 관리자, 일반 사용자, 게스트 등의 역할을 구분
IDOR 제한 (Access Control on Object References)	- API 호출 시 세션 사용자와 요청된 리소스의 사용자 검증
정책 기반 접근 제어 (PBAC, Policy-Based Access Control)	- 특정 조건(시간대, IP 주소)에 따라 접근 제어
서버 측 권한 검사 (Server-Side Authorization Checks)	- 클라이언트에서 권한 체크를 하지 않고, 서버에서 권한 검증 수행
CSRF 방지 (CSRF Token 사용)	- SameSite=strict, CSRF 토큰 검증 적용
보안 로깅 및 모니터링	- 관리자 권한 변경, 권한 상승 시도 등을 로깅 및 감시



요약 정리

- 인증은 사용자의 신원을 확인하는 과정이며, 인가는 인증된 사용자의 접근 권한을 결정하는 과정이다.
- 세션 기반 인증은 서버에서 세션을 관리하며, 토큰 기반 인증은 클라이언트가 토큰을 저장하고 요청 시 전송한다.
- 보안 강화를 위해 다중 인증(MFA), 비밀번호 없는 인증, 생체 인증 등의 방식이 활용된다.
- XSS, CSRF, 세션 하이재킹, 리플레이 공격 등의 위협을 방어하기 위해 입력값 검증, 보안 쿠키 설정, 토큰 서명 검증 등의 대책이 필요하다.
- 안전한 인증 시스템을 구축하려면 HTTPS/TLS를 통한 암호화, 최소 권한 원칙 적용, 이상 징후 모니터링이 필수적이다.



참고 문헌

- [KISA] 소프트웨어 개발 보안 가이드(2021.12.29)
- [KISA] 소프트웨어 보안약점 진단가이드(2021)
- [오픈이지북스] 실무에 바로 적용하는 해킹 방어를 위한 JAVA 시큐어코딩
- [홍릉과학출판사] 소프트웨어 개발 보안 실무 - 시큐어 코딩 원리와 실제
- [책만] 모두를 위한 소프트웨어 보안 설계와 구현 - 취약점 분석부터 위협 모델링과 완화 전략, 보안 패턴, 암호화까지 안전한 소프트웨어의 모든 것
- [한빛미디어] 웹 해킹 & 보안 완벽 가이드 - 웹 애플리케이션 보안 취약점을 겨냥한 공격과 방어

The background is a vibrant blue gradient. It is decorated with various abstract elements: a large solid blue sphere in the upper left, a smaller sphere with diagonal stripes in the upper right, and another striped sphere in the lower left. Several network diagrams, consisting of interconnected nodes and lines, are scattered across the image. There are also various rectangular and trapezoidal shapes in different shades of blue. In the top left corner, there is a small icon of three horizontal lines.

감사합니다.



퀴즈

1. 다음 중 인증과 인가에 대한 설명 중 잘못된 것은?

- 1) 인증은 사용자에게 리소스 접근 가능한 권한을 부여하는 것
- 2) 인가는 권한을 제한하는 것도 포함함
- 3) 인증은 이 사람이 누구인가를 확인하는 과정
- 4) 인가를 통해 사용자를 등급별로 구분할 수 있게 됨

2. 사용자의 역할에 따라 접근 권한을 부여하는 방식을 나타내는 용어는? (영문 4글자)

()

3. 다음중 인가 보안 위협에 대한 대응 방안은?

- 1) 최소권한의 원칙
- 2) 강력한 비밀번호 정책
- 3) CAPCHA 적용
- 4) 다중인증



퀴즈 정답

1. 다음 중 인증과 인가에 대한 설명 중 잘못된 것은?

1) 인증은 사용자에게 리소스 접근 가능한 권한을 부여하는 것

인증은 통해 누구인지 확인한 다음, 인가 과정을 통해 그 사용자에게 허용 권한을 부여합니다.

2. 사용자의 역할에 따라 접근 권한을 부여하는 방식을 나타내는 용어는? (영문 4글자)

(RBAC)

3. 다음중 인가 보안 위협에 대한 대응 방안은?

1) 최소권한원칙

모든 사용자는 필요한 최소한의 권한만 부여